

Reporte de solución de problemas matemáticos:
Evaluación de la calidad del software mediante métricas, verificación y
Auditoría

Carlos Alberto Archila Vargas

Corporación Universitaria Minuto de Dios
Estándares y Métricas de Calidad en el Desarrollo de Software
Semana 2 — Aseguramiento de la calidad del software: validación, verificación, revisiones y
auditorías

Cesar Alfonso Bolado Silva

13 de julio de 2026

Presentación

En el presente trabajo se propone el análisis de un **sistema de gestión de recaudos para empresas de servicios públicos** como caso de estudio para aplicar los conceptos de aseguramiento de la calidad del software. A partir de este escenario se desarrollan actividades de verificación, validación, revisión técnica, auditoría y definición de métricas, con el fin de identificar riesgos, evaluar el cumplimiento de los requisitos y plantear recomendaciones de mejora apoyadas en el modelo de calidad ISO/IEC 25010.

1. Escenario del caso "RecaudaPlus" v5.4

1.1 Descripción general del sistema

RecaudaPlus es un sistema de información utilizado por una empresa tecnológica que presta servicios de recaudo para empresas de servicios públicos domiciliarios, entre ellas empresas de energía eléctrica, acueducto, alcantarillado, gas natural e internet. El sistema centraliza el procesamiento de pagos realizados por los usuarios a través de diferentes canales, permitiendo que las empresas de servicios públicos reciban la información de los recaudos en tiempo real o mediante procesos automáticos de conciliación.

Actualmente el sistema procesa aproximadamente **450.000 transacciones diarias**, provenientes de más de **50 entidades financieras**, corresponsales bancarios, aplicaciones móviles y portales web de pago.

El sistema se encuentra en preparación para liberar la **versión 5.4**, la cual incorpora nuevas funcionalidades orientadas a mejorar la disponibilidad del servicio y ampliar los canales de recaudo digitales.

1.2 Contexto organizacional

- La empresa desarrolla el software utilizando la metodología **Scrum**, con ciclos de desarrollo de tres semanas.
- El equipo responsable de la versión está conformado por: 1 Product Owner, 1 Scrum Master, 5 desarrolladores Backend (.NET), 2 desarrolladores Frontend, 2 ingenieros DevOps y 2 analistas QA.
- La organización no cuenta con un equipo independiente de aseguramiento de calidad; las pruebas son realizadas por el mismo equipo de desarrollo y por QA antes de cada liberación.
- La empresa mantiene contratos con varias empresas de servicios públicos que establecen **acuerdos de nivel de servicio (SLA)** superiores al **99.9% de disponibilidad**, debido a que el sistema debe permanecer operativo durante campañas masivas de pago.
- La liberación de la versión 5.4 está programada para dentro de **cuatro semanas** y la fecha contractual no puede modificarse, ya que coincide con el inicio del periodo de mayor volumen de recaudos del año.

- La gerencia ha solicitado acelerar la salida a producción debido a que uno de sus principales competidores anunció la incorporación de pagos mediante billeteras digitales, funcionalidad que también será incluida en esta versión.

1.3 Actores involucrados

- **Ciudadanos:** Realizan el pago de sus facturas desde diferentes canales.
- **Cajeros bancarios:** Registran pagos realizados en oficinas físicas.
- **Corresponsales bancarios:** Procesan pagos en supermercados y puntos autorizados.
- **Empresas de servicios públicos:** Reciben la información de los recaudos para actualizar el estado de las facturas.
- **Administradores de recaudo:** Supervisan las transacciones, realizan conciliaciones y generan reportes financieros.
- **Administradores de TI:** Gestionan la infraestructura, bases de datos, servidores y usuarios privilegiados.
- **Área financiera:** Verifica conciliaciones, inconsistencias y reportes contables.
- **Equipo Scrum:** Desarrolla, prueba y despliega las nuevas funcionalidades.
- **Banco aliado:** Expone APIs para validar y confirmar los pagos electrónicos.

1.4 Versión 5.4 en preparación

La nueva versión incorpora funcionalidades estratégicas para la compañía:

- Integración con billeteras digitales.
- Nuevo módulo de conciliación automática.
- Optimización del procesamiento concurrente de pagos.
- Nuevo sistema de autenticación mediante OAuth2.
- Panel administrativo rediseñado.
- Generación automática de comprobantes electrónicos.
- Nuevo API para integración con empresas de servicios públicos.

1.5 Funcionalidades críticas

Las funcionalidades consideradas críticas para esta liberación son:

- **Autenticación y administración de usuarios:** Incluye autenticación OAuth2, recuperación de contraseña y control de sesiones.
- **Registro de recaudos:** Permite registrar pagos provenientes de bancos, corresponsales y aplicaciones móviles.
- **Conciliación bancaria automática:** Compara los pagos recibidos con la información enviada por los bancos y genera diferencias cuando existen inconsistencias.

- **Integración con APIs bancarias:** Recibe confirmaciones de pago en tiempo real mediante servicios REST.
- **Generación de comprobantes electrónicos:** Produce comprobantes digitales para el ciudadano y para la empresa de servicios públicos.
- **Administración de convenios:** Permite configurar empresas recaudadoras, bancos aliados y canales de pago.
- **Reportes financieros:** Genera informes de recaudos diarios, conciliaciones, recaudos pendientes y estadísticas operativas.
- **Auditoría de operaciones:** Registra todas las operaciones realizadas por usuarios y procesos automáticos.

1.6 Restricciones técnicas y regulatorias

El sistema debe cumplir múltiples restricciones debido a que procesa información financiera.

- **Seguridad:** Toda comunicación entre sistemas debe realizarse utilizando HTTPS con TLS 1.3.
- **Disponibilidad:** El servicio debe mantener una disponibilidad mínima del **99.9%**.
- **Rendimiento:** Debe procesar hasta **2.500 transacciones por minuto** sin degradación significativa.
- **Integridad:** Cada pago debe registrarse exactamente una vez (No pueden existir pagos duplicados).
- **Auditoría:** Toda operación administrativa debe quedar registrada con: Usuario, Fecha, Dirección IP, Acción realizada, Valor anterior, Valor nuevo
- **Protección de datos:** Los datos personales de los usuarios deben almacenarse cifrados conforme a la Ley 1581 de 2012.
- **Información financiera:** Los números completos de cuentas bancarias y tarjetas nunca deben almacenarse en texto plano dentro de registros o archivos de auditoría.
- **Integración:** La sincronización con los sistemas de facturación de las empresas de servicios públicos debe ejecutarse automáticamente cada noche sin pérdida de información.

1.7 Situación actual

Aunque la versión 5.4 presenta importantes mejoras funcionales, durante las pruebas internas comenzaron a detectarse incidentes que generan preocupación antes de la liberación.

En las últimas dos semanas se han reportado inconsistencias relacionadas con la seguridad, el procesamiento concurrente de pagos y la trazabilidad de las operaciones administrativas.

Algunos de estos incidentes todavía permanecen abiertos debido a la presión por cumplir la fecha de entrega, mientras que otros fueron corregidos parcialmente sin ejecutar nuevamente todas las pruebas de regresión.

La dirección de tecnología ha decidido solicitar una evaluación completa de aseguramiento de calidad antes de aprobar la liberación definitiva.

2. Evidencias disponibles

2.1 Fragmento de especificación de requisitos

ID	Descripción	Tipo	Prioridad	Estado actual
RF-001	El sistema debe utilizar autenticación OAuth2 con autenticación multifactor para todos los usuarios administrativos.	Funcional	Alta	Implementado parcialmente (MFA opcional).
RF-008	Toda la información financiera y personal deberá almacenarse cifrada mediante AES-256.	No funcional (Seguridad)	Alta	Pendiente de verificación.
RF-015	El sistema deberá procesar hasta 2.500 transacciones por minuto con un tiempo de respuesta inferior a 3 segundos (percentil 95).	No funcional (Rendimiento)	Alta	No probado bajo carga.
RF-021	Todas las operaciones administrativas deberán quedar registradas en un log de auditoría inmutable.	No funcional (Trazabilidad)	Alta	Solo se registran modificaciones, no consultas.
RF-030	Ningún pago podrá registrarse más de una vez para la misma factura.	Funcional	Alta	Pendiente de validación bajo concurrencia.
RF-041	Las integraciones con entidades financieras deberán utilizar TLS 1.3.	No funcional (Seguridad)	Alta	En desarrollo.
RF-050	El proceso de conciliación bancaria deberá completarse automáticamente cada noche sin pérdida de información.	Funcional	Alta	Implementado parcialmente.
RF-060	Los datos sensibles nunca deberán almacenarse completos en archivos de log.	No funcional (Cumplimiento)	Alta	Pendiente de auditoría.

2.2 Extracto de bitácora de incidencias

ID	Módulo	Descripción	Severidad	Estado
INC-101	Recaudos	Durante una prueba de concurrencia, dos solicitudes simultáneas registraron el mismo pago para una factura.	Alta	Abierto
INC-102	Administración	Tres administradores utilizan una única cuenta denominada admin_recaudos, sin autenticación multifactor ni expiración de contraseña.	Alta	Abierto
INC-103	API Bancaria	Durante las pruebas se detectó que algunas conexiones con un banco aliado continúan utilizando TLS 1.1 debido a una configuración heredada.	Alta	Abierto
INC-104	Auditoría	Los archivos de log almacenan el número completo de la cuenta bancaria del ciudadano cuando ocurre un error durante el recaudo.	Alta	Abierto
INC-105	Auditoría	El sistema registra quién modifica un convenio bancario, pero no quién consulta la información.	Media-Alta	Abierto
INC-106	Conciliación	El proceso automático de conciliación nocturna falló dos veces durante la última semana sin generar ninguna alerta al equipo de soporte.	Media	Abierto
INC-107	Rendimiento	La prueba de carga para validar 2.500 transacciones por minuto fue cancelada por falta de infraestructura.	Media	Pendiente

2.3 Lista de control de cambios

ID	Descripción del cambio	Módulo	Responsable	Revisado por	Estado
CR-201	Implementación de OAuth2	Seguridad	Dev 2	Líder Técnico	Desplegado
CR-202	Integración con billeteras digitales	Recaudos	Dev 5	Product Owner	Desplegado
CR-203	Actualización del módulo de conciliación bancaria	Conciliación	Dev 1	Líder Técnico	Pendiente

CR-204	Cambio de configuración TLS para API bancaria	Integraciones	DevOps	Sin registro	Desplegado
CR-205	Parche rápido para evitar pagos duplicados Recaudos	Recaudos	Dev 3	Sin registro	Desplegado

Nota: Los cambios CR-204 y CR-205 fueron desplegados directamente en producción sin evidencia de revisión técnica ni aprobación formal. Esto representa un incumplimiento del proceso de gestión de cambios y será relevante tanto en la lista de revisión técnica como en la auditoría.

2.4 Resultados de pruebas preliminares

Módulo	Tipo de prueba	Resultado	Observaciones
Registro de recaudos	Funcional	Aprobado	Dos defectos menores corregidos.
Conciliación bancaria	Funcional	Aprobado con observaciones	Existen diferencias cuando hay alta concurrencia.
Registro de pagos	Concurrencia	Fallida	Se detectó duplicidad de pagos (INC-101).
API Bancaria	Seguridad	Fallida	Persisten conexiones mediante TLS 1.1 (INC-103).
Auditoría	Seguridad	Aprobado con observaciones	Solo se registran modificaciones, no consultas (INC-105).
Rendimiento	Carga	No ejecutada	No existe ambiente para pruebas de 2.500 transacciones por minuto (INC-107).
Conciliación automática	Integración	Fallida intermitente	Dos ejecuciones nocturnas fallaron sin generar alertas (INC-106).
Billeteras digitales	Funcional	Aprobado	Sin observaciones.
Administración	Seguridad	Pendiente	No se evaluó autenticación multifactor obligatoria.

3. Hallazgos de seguridad identificados

N°	Hallazgo	Evidencia	Impacto
1	Procesamiento duplicado de pagos: durante pruebas de concurrencia se registró el mismo pago dos veces para una misma factura cuando dos solicitudes llegaron simultáneamente.	INC-101	Riesgo de inconsistencias financieras, errores en la conciliación bancaria y afectación de la integridad de la información contable. Puede generar

			devoluciones, reclamaciones de los usuarios y pérdidas económicas.
2	Uso de cuentas administrativas compartidas: varios administradores utilizan la misma cuenta privilegiada (admin_recaudos), sin autenticación multifactor ni expiración de contraseña.	INC-102	Se pierde la trazabilidad de las acciones administrativas, aumenta el riesgo de accesos no autorizados y se dificulta la investigación de incidentes de seguridad.
3	Comunicación insegura con entidades financieras: algunas integraciones continúan utilizando TLS 1.1 debido a configuraciones heredadas, en lugar de TLS 1.3.	INC-103	La información financiera transmitida entre sistemas puede quedar expuesta a vulnerabilidades conocidas, comprometiendo la confidencialidad e integridad de las transacciones.
4	Exposición de información sensible en archivos de auditoría: los registros del sistema almacenan números completos de cuentas bancarias cuando ocurre un error durante el procesamiento del recaudo.	INC-104	Incumplimiento de las políticas de protección de datos y aumento del riesgo de fuga de información financiera en caso de acceso no autorizado a los registros.
5	Auditoría incompleta de operaciones administrativas: el sistema registra únicamente las modificaciones realizadas sobre convenios y configuraciones, pero no las consultas efectuadas por los administradores.	INC-105	No es posible reconstruir completamente las actividades realizadas sobre información crítica, dificultando la detección de accesos indebidos y las investigaciones posteriores a un incidente.

4. Matriz de verificación y validación

ID	Requisito / Funcionalidad	Tipo	Técnica a aplicar	Responsable	Criterio de aceptación
RF-001	Autenticación OAuth2 con autenticación multifactor (MFA) para usuarios administrativos	Verificación	Revisión de código, inspección de configuración y revisión de políticas de autenticación	Líder Técnico	MFA habilitado y obligatorio para todos los usuarios administrativos
RF-008	Cifrado de la información financiera y datos personales mediante AES-256	Verificación	Inspección de configuración de cifrado, revisión de base de datos y revisión del código	Administrador de Base de Datos / Líder Técnico	Todos los datos sensibles almacenados utilizando AES-256

RF-015	Procesamiento de 2.500 transacciones por minuto con tiempo de respuesta menor a 3 segundos (P95)	Validación	Pruebas de carga y rendimiento utilizando herramientas de simulación de usuarios concurrentes	Equipo QA	Tiempo de respuesta menor a 3 segundos en el percentil 95 durante toda la prueba
RF-021	Registro de auditoría de todas las operaciones administrativas (consultas y modificaciones)	Verificación	Revisión de código, inspección de logs y revisión de políticas de auditoría	Líder Técnico	Todas las operaciones administrativas quedan registradas de forma inmutable
RF-030	Evitar el registro duplicado de pagos para una misma factura	Validación	Pruebas funcionales de concurrencia y procesamiento simultáneo de transacciones	Equipo QA	Ninguna factura puede registrar pagos duplicados bajo escenarios concurrentes
RF-041	Integración segura con entidades financieras utilizando TLS 1.3	Verificación	Inspección de certificados digitales, revisión de configuración del servidor y pruebas de seguridad	Administrador de Infraestructura	Todas las comunicaciones utilizan exclusivamente TLS 1.3
RF-050	Ejecución automática del proceso de conciliación bancaria nocturna	Validación	Prueba de integración entre el sistema de recaudos y las entidades financieras	Equipo QA y Administrador de TI	El proceso finaliza correctamente sin pérdida de información ni diferencias contables
RF-060	Protección de información sensible en archivos de auditoría y registros del sistema	Verificación	Revisión de configuración de logs, inspección de archivos y auditoría de seguridad	Oficial de Seguridad de la Información	Ningún dato sensible (cuentas bancarias, tarjetas o información personal) aparece completo en los registros del sistema

5. Lista de control de revisiones técnicas

N°	Ítem de revisión	Cumple	Observaciones / evidencia
1	El código fuente cumple los estándares de codificación definidos por el equipo.	N.A.	El escenario no proporciona evidencia sobre estándares de codificación ni resultados de revisiones de código
2	Existe trazabilidad entre los requisitos y los casos de prueba.	No	Los requisitos RF-015 (pruebas de carga) y RF-060 (protección de datos en logs) permanecen pendientes de validación o auditoría, por lo que no existe evidencia completa de pruebas ejecutadas.
3	Todos los cambios fueron documentados, revisados y aprobados antes de su despliegue a producción.	No	Los cambios CR-204 (configuración TLS) y CR-205 (Parche rápido para pagos duplicados) fueron desplegados sin evidencia de revisión técnica ni aprobación formal.
4	Los mecanismos de autenticación y autorización protegen adecuadamente los recursos críticos del sistema.	No	La autenticación multifactor es opcional (RF-001) y existen cuentas administrativas compartidas (INC-102).
5	La información sensible se almacena y transmite utilizando mecanismos de cifrado adecuados.	No	Persisten conexiones utilizando TLS 1.1 (INC-103) y el cifrado de datos sensibles (RF-008) continúa pendiente de verificación.
6	Existen registros de auditoría para todas las operaciones críticas del sistema.	No	El sistema registra únicamente las modificaciones administrativas; las consultas no quedan registradas (INC-105, RF-021).
7	Se ejecutaron pruebas de seguridad antes de la liberación de la versión.	No	La validación del cumplimiento de TLS 1.3 y la auditoría de protección de datos sensibles aún se encuentran pendientes (RF-041, RF-060).
8	Se ejecutaron pruebas de carga y concurrencia sobre los módulos críticos.	No	La prueba de carga para 2.500 transacciones por minuto no fue ejecutada (INC-107) y las pruebas de concurrencia evidenciaron pagos duplicados (INC-101).
9	El manejo de la información financiera y los datos personales cumple las políticas de protección de datos establecidas por la organización.	No	Los archivos de auditoría almacenan números completos de cuentas bancarias (INC-104) y el cifrado de información aún no ha sido verificado (RF-008).
10	El proceso de conciliación bancaria opera de forma automática y confiable.	No	El proceso de conciliación nocturna presentó fallos sin generar alertas automáticas (INC-106).

11	Las integraciones con entidades financieras cumplen los requisitos de seguridad establecidos.	No	Se identificaron integraciones que continúan utilizando TLS 1.1 en lugar de TLS 1.3 (INC-103).
12	Existen mecanismos automáticos de monitoreo y alertas para procesos críticos.	No	El proceso de conciliación falló en varias oportunidades sin notificar al equipo de soporte (INC-106).
13	La documentación técnica y operativa está actualizada para la versión 5.4.	N.A.	El escenario no presenta evidencia sobre el estado de la documentación técnica ni de usuario.
14	Los riesgos técnicos y de seguridad identificados fueron mitigados antes de la liberación.	No	Permanecen abiertos incidentes críticos relacionados con pagos duplicados, autenticación, cifrado, auditoría y protección de datos (INC-101 a INC-106).

6. Hallazgos de auditoría

6.1 Datos generales

Campo	Contenido
Objetivo de la auditoría	Evaluar el cumplimiento de los requisitos funcionales y no funcionales del sistema RecaudaPlus versión 5.4, verificando la seguridad, confiabilidad, rendimiento, trazabilidad y cumplimiento de las políticas de calidad antes de su liberación a producción
Alcance	La auditoría comprende los módulos de autenticación, registro de recaudos, conciliación bancaria, integración con entidades financieras, administración de convenios, generación de comprobantes electrónicos y auditoría de operaciones de la versión 5.4.
Criterios de auditoría (normas/estándares de referencia)	• ISO/IEC 25010:2023 (Modelo de calidad del software). • Ley 1581 de 2012 (Protección de Datos Personales). • PCI-DSS (Protección de información financiera). • Políticas internas de seguridad y gestión de cambios de la organización. • Requisitos funcionales y no funcionales definidos para la versión 5.4.
Equipo auditor	Especialista de Aseguramiento de Calidad (Auditor líder), Analista QA y Administrador de Seguridad de la Información.
Fecha de ejecución	13 de julio de 2026.
Evidencias a recolectar	Especificación de requisitos (RF), bitácora de incidencias (INC), lista de control de cambios (CR), resultados de pruebas preliminares, registros de auditoría (logs), configuraciones de seguridad, reportes de conciliación bancaria y documentación técnica del sistema.

6.2 Hallazgos

N°	Hallazgo	Criterio incumplido	Evidencia	Severidad	Recomendación
1	Se detectó el registro duplicado de pagos durante pruebas de concurrencia.	RF-030. Integridad de las transacciones financieras. ISO/IEC 25010 – Fiabilidad.	INC-101. Pruebas de concurrencia fallidas.	Alta	Implementar mecanismos de control de concurrencia e idempotencia para garantizar que una factura solo pueda registrarse una vez. Ejecutar nuevamente las pruebas de concurrencia antes de la liberación.
2	Existen cuentas administrativas compartidas y la autenticación multifactor no es obligatoria para usuarios privilegiados.	RF-001. Controles de autenticación. ISO/IEC 25010 – Seguridad.	INC-102. Configuración de autenticación.	Alta	Asignar cuentas individuales a cada administrador, habilitar MFA obligatorio y establecer políticas de expiración de contraseñas.
3	Algunas integraciones con entidades financieras continúan utilizando TLS 1.1.	RF-041. Seguridad de las comunicaciones. PCI-DSS. ISO/IEC 25010 – Seguridad.	INC-103. Configuración del servidor.	Alta	Actualizar todas las integraciones para utilizar exclusivamente TLS 1.3 y validar nuevamente la configuración mediante pruebas de seguridad.
4	Los archivos de auditoría almacenan información financiera sensible sin enmascaramiento.	RF-060. Protección de datos sensibles. Ley 1581 de 2012. PCI-DSS.	INC-104. Revisión de archivos de log.	Alta	Configurar el sistema para enmascarar o eliminar datos sensibles de los registros y realizar una auditoría completa sobre los archivos existentes.
5	El proceso de auditoría registra únicamente modificaciones administrativas, pero no las consultas	RF-021. Trazabilidad de operaciones. ISO/IEC 25010 – Seguridad.	INC-105. Revisión de registros de auditoría.	Media	Ampliar el mecanismo de auditoría para registrar todas las consultas y accesos a información crítica, fortaleciendo la

	realizadas por los usuarios.				trazabilidad y facilitando futuras investigaciones.
--	------------------------------	--	--	--	---

6.3 Conclusión general

La auditoría realizada sobre la versión 5.4 del sistema RecaudaPlus evidenció que la solución presenta avances funcionales importantes; sin embargo, aún existen hallazgos críticos que comprometen la seguridad, la integridad de la información y la confiabilidad del sistema. Entre los principales riesgos identificados se encuentran la posibilidad de registrar pagos duplicados, el uso de cuentas administrativas compartidas, la utilización de protocolos de comunicación obsoletos, la exposición de información financiera en los registros del sistema y la falta de trazabilidad completa sobre las operaciones administrativas.

Con base en las evidencias analizadas y en los criterios establecidos por ISO/IEC 25010, PCI-DSS y la Ley 1581 de 2012, no se recomienda la liberación de la versión 5.4 a producción hasta que los hallazgos de severidad alta hayan sido corregidos, verificados y validados mediante nuevas pruebas. Una vez implementadas las acciones correctivas, se deberá realizar una auditoría de seguimiento para confirmar el cumplimiento de los requisitos de calidad y seguridad definidos para el sistema.

6.4 Firma

Auditor	Fecha
Carlos Archila Especialista en Desarrollo de software	13 de julio de 2026

Referencias

- Carrizo, D., & Alfaro, A. (2018). *Método de aseguramiento de la calidad en una metodología de desarrollo de software: Un enfoque práctico*. Ingeniare: Revista Chilena de Ingeniería.
- Chavarría, A. E., Oré, S. B., & Pastor, C. (2016). Aseguramiento de la calidad en el proceso de desarrollo de software utilizando CMMI, TSP y PSP. *Revista Ibérica de Sistemas e Tecnologías de Informação*, (20), 62–77.
- IEEE. (2014). *IEEE Std 730-2014: IEEE Standard for Software Quality Assurance Processes*. Institute of Electrical and Electronics Engineers.
- International Organization for Standardization. (2023). *ISO/IEC 25010:2023. Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — Product quality model*. ISO.

Universidad Minuto de Dios. (2026). *Semana 2: Aseguramiento de la calidad del software: validación, verificación, revisiones y auditorías* [Material de curso].